**FACULTAD DE DEFENSA NACIONAL (FADENA)**
**LICENCIATURA EN CIBERDEFENSA**
**ASIGNATURA: TECNOLOGÍA OPERATIVA (2026)**
**UNIDAD 2: CONTROLADORES Y LÓGICA DE AUTOMATIZACIÓN**

**DOCUMENTO DE CÁTEDRA N° 8.**

# TEMA: LA HMI — EL OPERADOR EN EL LOOP DE CONTROL.

***Apertura: Lo que el operador ve es lo que el sistema hace.***

El 23 de diciembre de 2015, los operadores del centro de control de la distribuidora eléctrica Prykarpattyaoblenergo en Ucrania miraban sus pantallas con creciente desconcierto. Los cursores de sus HMIs se movían solos. Las subestaciones se desconectaban una tras otra. Intentaron tomar el control manual, pero los sistemas respondían a otro. En paralelo, una llamada masiva de denegación de servicio telefónica saturaba el centro de atención al cliente, impidiendo que los usuarios reportaran el corte. Y la HMI de respaldo — el sistema que debería haber mostrado el estado real de la red cuando la principal fallara — mostraba datos estáticos: el malware había reemplazado las imágenes de estado con capturas de pantalla del estado normal, congeladas en el tiempo.

Este ataque — documentado como el primero en la historia en producir un apagón masivo por medios puramente cibernéticos — se consuma en la HMI. No porque la pantalla sea el objetivo final, sino porque la pantalla es lo que separa al operador humano de la realidad física del proceso. Controlar lo que el operador ve equivale, en la doctrina del adversario, a controlar al operador.

**Ubicación en el Programa:**

Este Documento N° 8 cierra la Unidad 2 con el análisis de la Interfaz Hombre-Máquina (HMI): su diseño, tipos, principios de usabilidad crítica para entornos industriales, vulnerabilidades documentadas y su rol como vector de ataque de alto impacto. Los documentos N° 5 (PLC), N° 6 (Ladder) y N° 7 (RTU) son prerequisitos conceptuales y forman el sistema que la HMI representa y sobre el cual el operador actúa.

## Objetivos de Aprendizaje.

Al finalizar la lectura de este documento, el alumno será capaz de:

- Definir la HMI y describir sus tipos según el contexto de implementación.
- Identificar los elementos de diseño estándar de una HMI industrial (sinópticos, alarmas, tendencias, controles) y su función operativa.
- Aplicar los principios de usabilidad crítica para entornos de alta consecuencia al análisis de una HMI dada.
- Reconocer las vulnerabilidades más frecuentes de las HMIs industriales y clasificarlas según la tríada AIC.
- Analizar el alarm flooding como técnica de ataque y su aplicación documentada en el incidente de Ucrania 2015.

- Relacionar el compromiso de la HMI con los niveles inferiores del sistema (PLC, RTU) estudiados en los documentos anteriores.

## 1. Definición y Función de la HMI.

La Interfaz Hombre-Máquina (HMI, por sus siglas en inglés Human-Machine Interface) es el componente del sistema de control que permite al operador humano observar el estado del proceso físico y actuar sobre él mediante comandos. En la terminología de la ingeniería de sistemas, la HMI es el punto de contacto entre el lazo de control automático (PLC/RTU → proceso físico) y el lazo de control cognitivo (operador → decisión → acción).

Knapp y Langill (2015) describen a la HMI como la 'ventana al proceso': todo lo que el operador sabe sobre lo que está ocurriendo en el campo proviene de lo que la HMI le muestra. Esta dependencia epistémica — el operador conoce la realidad solo a través de la pantalla — es simultáneamente el principio de diseño que hace posible la supervisión remota de infraestructuras complejas y la vulnerabilidad fundamental que el adversario puede explotar.

> **Conexión con Unidad 1 — Tríada AIC y la HMI:**
>
> En el Documento N° 1 establecimos que en entornos OT la prioridad es AIC: Disponibilidad, Integridad, Confidencialidad. La HMI concentra la exposición a dos de estos tres principios de forma simultánea: un ataque a la Integridad de la HMI (mostrar datos falsos) afecta la toma de decisiones del operador sin interrumpir el proceso; un ataque a la Disponibilidad de la HMI (bloquear la pantalla, sobrecargarla de alarmas) priva al operador de la capacidad de supervisión en el momento crítico. Ambos vectores fueron utilizados coordinadamente en el ataque a Ucrania 2015.

## 2. Tipos de HMI según el Contexto de Implementación.

No existe una única forma de HMI: su diseño y ubicación varían según la escala del proceso supervisado, las condiciones ambientales y la criticidad de la operación. La siguiente tabla clasifica los tipos más frecuentes:

| Tipo de HMI | Características | Relevancia en Ciberdefensa |
|---|---|---|
| **Panel local (HMI embebida)** | Pantalla táctil o de teclas integrada directamente en el tablero del PLC o en el equipo. Sin conexión de red en muchos casos. Operación local. | Acceso físico requerido para comprometer. El vector de ataque es el acceso físico al tablero. Menor exposición remota, mayor importancia de la seguridad perimetral física. |
| **Estación de operación (PC con software SCADA/HMI)** | Computadora convencional o industrial con software propietario (Wonderware, iFIX, Ignition, WinCC). Conectada a la red industrial. Puede supervisar múltiples PLCs y RTUs simultáneamente. | Vector de ataque principal en entornos IT/OT convergidos. Frecuentemente ejecuta Windows legacy (XP, 7) sin parches. Punto de entrada para malware mediante USB, correo phishing o exploit de red. Es el componente que el atacante de Ucrania 2015 controló de forma remota. |
| **HMI Web (Browser-based)** | Interfaz accesible desde un navegador web estándar. Permite supervisión remota sin software cliente instalado. Tecnología moderna (HTML5, WebSockets). | Expuesta a vectores de ataque web: XSS (Cross-Site Scripting), CSRF (Cross-Site Request Forgery), credenciales débiles en portal de acceso. Si el acceso remoto no está protegido con VPN y MFA, cualquier usuario de internet puede intentar acceder. |

| Tipo de HMI | Características | Relevancia en Ciberdefensa |
|---|---|---|
| **HMI móvil (tablet/smartphone)** | Aplicación en dispositivo móvil que permite supervisión y control desde cualquier ubicación. Creciente adopción en mantenimiento de campo. | Dispositivo personal en red industrial: superficie de ataque ampliada. Pérdida o robo del dispositivo. Aplicaciones sin cifrado de sesión. Riesgo de instalación de apps maliciosas en el dispositivo del operador que capturen credenciales OT. |

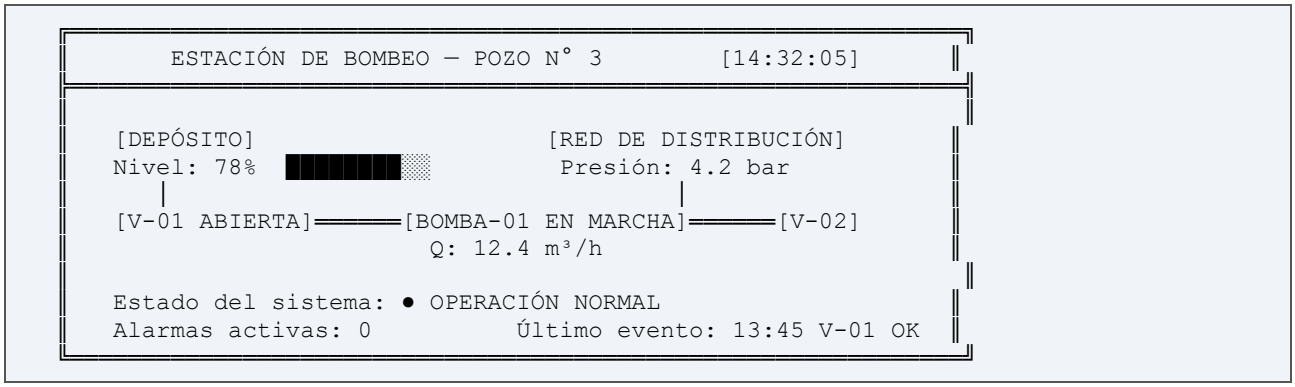
## 3. Elementos de Diseño de una HMI Industrial.

Una HMI industrial bien diseñada no es simplemente una pantalla con datos: es un instrumento de toma de decisiones bajo condiciones de estrés, tiempo limitado y consecuencias físicas inmediatas. Sus elementos de diseño deben responder a este contexto de alta consecuencia.

### 3.1. El Sinóptico: La Vista del Proceso.

El sinóptico es la representación gráfica del proceso físico supervisado. Muestra la topología del sistema (tuberías, válvulas, depósitos, motores, líneas eléctricas) y superpone sobre ella los valores en tiempo real de las variables de proceso. Es el elemento central de toda HMI industrial.

El siguiente ejemplo muestra la representación esquemática de un sinóptico de control de una estación de bombeo de agua, en notación simplificada:




Desde la perspectiva de la Ciberdefensa, el sinóptico es el objetivo de la falsificación de estado: si un adversario puede controlar qué valores muestra la HMI — independientemente de lo que ocurra en el proceso real — puede hacer que el operador tome decisiones basadas en una realidad fabricada. El ataque de Ucrania 2015 reemplazó las imágenes dinámicas del sinóptico con capturas estáticas del estado normal, exactamente este vector.

### 3.2. El Sistema de Alarmas.

El sistema de alarmas es el mecanismo por el cual la HMI alerta al operador cuando una variable del proceso supera un umbral predefinido o cuando ocurre un evento que requiere atención. Es la primera línea de defensa del operador ante condiciones anómalas.

Un sistema de alarmas bien configurado responde a la norma ANSI/ISA-18.2 (Management of Alarm Systems for the Process Industries), que establece principios de diseño orientados a que el operador pueda procesar las alarmas con eficacia bajo condiciones de estrés:

- **Priorización:** Las alarmas deben clasificarse según su urgencia y consecuencia (Prioridad 1 — acción inmediata requerida; Prioridad 2 — atención en minutos; Prioridad 3 — acción diferida). Sin priorización, todas las alarmas parecen igual de urgentes.
- **Tasa de alarmas manejable:** La norma ISA-18.2 establece como objetivo no superar las 10 alarmas por operador por hora en condiciones normales, y no más de 10 alarmas por minuto en situaciones de disturbio. Una tasa mayor supera la capacidad cognitiva del operador.
- **Alarmas accionables:** Cada alarma debe requerir una acción específica del operador. Las alarmas informativas sin acción asociada generan 'ruido' que reduce la atención a las alarmas críticas.
- **Supresión controlada:** Durante mantenimiento o condiciones conocidas, algunas alarmas pueden suprimirse temporalmente. El registro de supresiones es crítico para la auditoría de seguridad.

### 3.3. Tendencias (Trends): La Historia del Proceso.

El display de tendencias muestra la evolución temporal de las variables del proceso en un gráfico de línea. Es el componente de la HMI que permite al operador identificar patrones, detectar degradaciones graduales y reconstruir la secuencia de eventos ante un incidente.

Desde la perspectiva forense, el display de tendencias es la primera herramienta que un analista de Ciberdefensa examina al llegar a una sala de control tras un incidente: la curva de una variable de proceso puede mostrar claramente si una anomalía fue gradual (falla mecánica) o abrupta y fuera del rango normal de operación (intervención externa).

> **Nota de Ciberdefensa (Integridad del Histórico):**
>
> Los datos de tendencias se almacenan en el servidor historian del sistema SCADA. Si un adversario logra acceso de escritura al historian, puede modificar retroactivamente los datos históricos del proceso, eliminando la evidencia de su intervención del registro de tendencias. Esta es una forma de anti-forense específica de entornos OT. La contramedida es replicar los datos de tendencias en un servidor de auditoría físicamente separado con acceso de escritura restringido, o utilizando técnicas de sellado criptográfico (hash encadenado de registros).

### 3.4. Controles de Mando.

Los controles de mando son los elementos interactivos de la HMI que permiten al operador enviar comandos al proceso: botones de marcha/parada, selectores de modo, campos de entrada para setpoints (valores de consigna) y controles de válvulas. Representan el camino inverso al de la visualización: del operador hacia el proceso físico.

Desde la perspectiva de la seguridad, los controles de mando de la HMI son el punto donde una sesión comprometida produce daño físico. Un adversario que toma el control de la sesión del operador — ya sea por acceso remoto legítimo mal protegido, por inyección de comandos mediante malware, o por session hijacking — puede emitir comandos al proceso exactamente como lo haría el operador autorizado.

## 4. Principios de Usabilidad Crítica para Entornos de Alta Consecuencia.

El diseño de HMIs para entornos industriales críticos no es equivalente al diseño de interfaces de usuario convencionales. Las condiciones de operación son radicalmente diferentes: el operador puede estar gestionando un incidente de alta presión, con múltiples alarmas activas, en turnos

nocturnos y con la conciencia de que un error puede costar vidas o producir daño ambiental. Los principios de usabilidad deben responder a este contexto.

| Principio | Descripción | Falla típica y consecuencia |
|---|---|---|
| **Jerarquía de información clara** | La información más crítica (alarmas activas, estado de equipos de seguridad) debe ser visible sin necesidad de navegar entre pantallas. El operador no debe buscar lo urgente. | Pantallas sobrecargadas de datos secundarios que ocultan visualmente las alarmas críticas. El operador demora segundos en encontrar la información relevante bajo presión — segundos que en un proceso crítico pueden ser decisivos. |
| **Consistencia visual** | Los colores, iconos y convenciones de representación deben ser uniformes en todas las pantallas. Rojo = alarma crítica, verde = normal, amarillo = advertencia deben ser invariantes. | Inconsistencia entre pantallas del mismo sistema lleva a errores de interpretación. Un operador que asume que amarillo significa advertencia en todas las pantallas puede ignorar una condición crítica representada en amarillo en una pantalla donde el estándar fue aplicado de forma diferente. |
| **Prevención de errores de acción irreversible** | Las acciones con consecuencias irreversibles (apertura de válvulas de emergencia, comandos de parada de turbinas) deben requerir confirmación explícita y diferenciarse visualmente de acciones rutinarias. | Un operador bajo estrés que accidentalmente activa un control adyacente al que buscaba puede producir un evento físico no deseado. El diseño de la pantalla comparte responsabilidad en este tipo de incidente. |
| **Soporte a la conciencia situacional** | La HMI debe proveer al operador no solo valores de variables sino una representación integrada del estado del sistema que permita inferir la tendencia del proceso (¿está mejorando o empeorando?). | Una HMI que solo muestra valores instantáneos sin contexto histórico ni indicadores de tendencia obliga al operador a construir el modelo del proceso mentalmente, aumentando la carga cognitiva en el peor momento posible. |
| **Gestión de alarmas ajustada a la norma ISA-18.2** | El sistema de alarmas debe estar racionalizado: solo alarmas accionables, priorizadas, sin alarmas repetitivas o de valor marginal que generen ruido. | Un sistema con cientos de alarmas simultáneas en estado normal (alarm flood crónico) entrena al operador a ignorarlas. Cuando ocurre una alarma genuinamente crítica, se pierde en el ruido. |

## 5. Vulnerabilidades Comunes de las HMIs Industriales.

Las HMIs industriales concentran un conjunto de vulnerabilidades que resultan de la convergencia entre las exigencias del entorno industrial (largo ciclo de vida, disponibilidad continua, resistencia al cambio) y la adopción de tecnologías de IT (sistemas operativos de propósito general, conectividad de red, software con actualizaciones frecuentes). La tabla siguiente sistematiza las vulnerabilidades más documentadas:

| Vulnerabilidad | Descripción técnica | Impacto según tríada AIC |
|---|---|---|
| **Sistema operativo legacy sin parches** | La mayoría de las HMIs industriales ejecutan Windows | Disponibilidad e Integridad: vulnerabilidades conocidas y públicamente documentadas (ej. |

| Vulnerabilidad | Descripción técnica | Impacto según tríada AIC |
|---|---|---|
| | XP, Windows 7 o versiones obsoletas de Linux que ya no reciben actualizaciones de seguridad del fabricante. Su reemplazo implica revalidar el software SCADA/HMI, con costo y riesgo operativo elevados. | EternalBlue / MS17-010) pueden ser explotadas para ganar ejecución de código en la HMI, comprometiendo tanto la visualización como la capacidad de comando. |
| **Credenciales por defecto o débiles** | Software HMI frecuentemente instalado con usuarios y contraseñas por defecto no modificados (admin/admin, operator/operator). Algunos sistemas tienen cuentas de servicio con contraseñas hardcodeadas en el código del fabricante. | Confidencialidad e Integridad: acceso no autorizado a la interfaz de operación con privilegios completos. El adversario puede operar el proceso exactamente como lo haría el operador autorizado. |
| **Exposición de la HMI en red IT/OT convergida** | La HMI conectada tanto a la red OT (para comunicar con PLCs/RTUs) como a la red IT corporativa (para reportes, acceso remoto) funciona como puente involuntario entre ambas redes si no existe segmentación adecuada. | Todos los principios AIC: la HMI se convierte en el punto de pivoting del adversario que ingresó por la red IT y busca acceder a la red OT. Este es el vector documentado en el caso Industroyer/Ucrania 2015. |
| **Software de acceso remoto sin protección** | Herramientas de soporte remoto (TeamViewer, VNC, RDP) instaladas en la HMI para permitir el acceso del proveedor de mantenimiento, frecuentemente con contraseñas débiles o sin autenticación multifactor. | Disponibilidad: el acceso remoto no autorizado puede usarse para bloquear la HMI durante un ataque. Integridad: el adversario puede manipular la visualización o emitir comandos de control directamente desde el acceso remoto comprometido. |
| **Puertos USB habilitados** | Los puertos USB de la PC de HMI frecuentemente están habilitados para facilitar actualizaciones y backups. En entornos operativos con alta rotación de personal de mantenimiento, el control de dispositivos USB es laxo. | Integridad: vector de introducción de malware mediante USB infectado (vector documentado en el caso Stuxnet, que se propagó inicialmente mediante memorias USB en instalaciones sin conexión a internet). |

## 6. Alarm Flooding: La Táctica de la Sobrecarga Cognitiva.

Entre todas las técnicas de ataque que utilizan la HMI como vector, el alarm flooding (inundación de alarmas) merece análisis específico por dos razones: es de implementación relativamente sencilla y produce un efecto operativo devastador que trasciende el sistema técnico para atacar directamente la capacidad de respuesta del ser humano.

### 6.1. Mecánica del Alarm Flooding.

El alarm flooding consiste en generar artificialmente un volumen de alarmas tan elevado que supere la capacidad cognitiva del operador para procesarlas, clasificarlas y actuar sobre las prioritarias. A diferencia de un ataque de DoS técnico que bloquea un sistema, el alarm flooding bloquea al operador dejando el sistema técnico funcionando.

Las alarmas pueden generarse de múltiples formas:

- **Manipulación de variables de proceso:** Si el adversario tiene acceso a los PLCs o RTUs (como vimos en los Docs N° 5 y 7), puede forzar variables fuera de sus límites normales, generando alarmas legítimas en cascada.
- **Inyección directa de mensajes de alarma:** En sistemas con protocolos de alarma sin autenticación, el adversario puede inyectar paquetes de alarma directamente al servidor historian o al servidor de alarmas del SCADA.
- **Explotación de la configuración de alarmas:** Si el adversario modifica los umbrales de alarma en el servidor SCADA (haciéndolos extremadamente sensibles), cualquier variación normal del proceso genera alarmas, sin necesidad de manipular el proceso físico.

## 6.2. El Ataque a Ucrania 2015: Alarm Flooding como Componente Táctico.

El análisis forense del ataque a la red eléctrica ucraniana de 2015 (Industroyer / Sandworm) documentó el uso coordinado del alarm flooding como componente de una operación de múltiples fases. La secuencia táctica fue la siguiente:

**Análisis Forense — Secuencia Táctica del Ataque a Ucrania 2015:**

FASE 1 — Preparación (meses antes del ataque):

El malware Industroyer fue instalado en las HMIs de las subestaciones mediante correos de spear-phishing dirigidos al personal de IT de las distribuidoras. Durante meses, el malware permaneció latente recolectando credenciales y mapeando la arquitectura de la red OT.

FASE 2 — Ejecución coordinada (23 de diciembre, hora pico de demanda):

A las 15:30 hora local, el malware activó simultáneamente tres acciones:

(a) Toma de control remoto de las HMIs: los operadores vieron sus cursores moverse.

(b) Apertura de disyuntores en 30 subestaciones mediante comandos SCADA directos.

(c) Activación de un sistema de denegación de servicio telefónica (TDoS) contra el call center.

FASE 3 — Alarm Flooding y bloqueo de recuperación:

Simultáneamente a la apertura de disyuntores, el sistema generó un volumen masivo de alarmas en las HMIs. El personal de sala de control, ya desorientado por el movimiento autónomo de cursores, enfrentó una pantalla de alarmas imposible de priorizar. La carga cognitiva fue tal que los operadores tardaron minutos en tomar la decisión de pasar a control manual local.

FASE 4 — Persistencia del efecto (KillDisk):

Una vez ejecutado el ataque, el malware sobreescribió el MBR (Master Boot Record) de las PCs de HMI con KillDisk, dejándolas inutilizables. Los técnicos debieron viajar físicamente a las 30 subestaciones para restaurar el control manualmente.

Resultado: 230.000 personas sin electricidad, algunas durante más de 6 horas en pleno invierno.

Lo que este análisis revela para la doctrina de Ciberdefensa es que el alarm flooding no es el ataque principal: es el componente que deshabilita la capacidad de respuesta humana mientras el ataque principal se ejecuta. Es, en términos militares, el fuego de supresión que paraliza al defensor mientras se ejecuta la maniobra de ruptura.

## 7. La HMI como Superficie de Ataque: Síntesis del Vector.

La HMI concentra en un único nodo las vulnerabilidades de todas las capas estudiadas en la Unidad 2. Para el adversario sofisticado, la HMI no es solo un objetivo: es el punto de control óptimo porque desde ella se puede observar el proceso (inteligencia), manipular la visualización del operador (engaño) y emitir comandos al sistema (acción).

| Nivel de acceso logrado | Capacidad del adversario desde la HMI | Ejemplo documentado |
|---|---|---|
| **Lectura de pantalla (pasivo)** | Obtener inteligencia operativa: estado del proceso, topología del sistema, variables críticas, turnos de operadores, secuencias de eventos normales. | Fase de reconocimiento en el caso Industroyer: meses de observación pasiva antes del ataque activo. |
| **Control de sesión (activo)** | Emitir comandos al proceso exactamente como el operador autorizado: abrir válvulas, disparar disyuntores, modificar setpoints, silenciar alarmas. | Ucrania 2015: el atacante tomó control de las HMIs y abrió disyuntores directamente desde la interfaz del operador. |
| **Manipulación de visualización** | Mostrar al operador un estado falso del proceso mientras el ataque se ejecuta: congelar sinópticos, mostrar valores normales falsos, suprimir alarmas. | Ucrania 2015: las HMIs de respaldo mostraron capturas estáticas del estado normal mientras la red colapsaba. |
| **Destrucción del nodo HMI** | Inutilizar la HMI como herramienta de recuperación, forzando al operador a intervención física en campo. | KillDisk en Ucrania 2015: sobreescritura del MBR de las PCs de HMI, dejándolas inutilizables. |
| **Pivoting hacia la red OT** | Usar la HMI como trampolín hacia la red industrial para acceder directamente a PLCs, RTUs y servidores SCADA sin necesidad de comprometer otros nodos. | Vector de Industroyer: ingreso por la red IT corporativa → pivot a través de la HMI hacia la red OT de subestaciones. |

## 8. Contramedidas de Seguridad para HMIs Industriales.

La defensa de las HMIs industriales requiere un enfoque diferente al de la ciberseguridad IT convencional, porque las medidas estándar (actualizaciones automáticas, antivirus en tiempo real, escaneos activos de vulnerabilidades) pueden interferir con la disponibilidad y el rendimiento determinista que el sistema de control requiere. Las contramedidas deben ser específicas para el contexto OT:

- **Endurecimiento del sistema operativo (Hardening):** Deshabilitar servicios, puertos y usuarios no necesarios. Bloquear puertos USB mediante política de grupo o bloqueadores físicos. Aplicar parches de seguridad en ventanas de mantenimiento planificadas, validando compatibilidad con el software SCADA antes de la aplicación.
- **Autenticación robusta:** Reemplazar credenciales por defecto por contraseñas fuertes únicas. Implementar autenticación multifactor (MFA) para acceso remoto. Eliminar cuentas compartidas: cada operador debe tener su propio usuario identificable para mantener trazabilidad de acciones.
- **Segmentación de red y control de acceso:** La HMI no debe tener conectividad directa a la red IT corporativa sin pasar por un firewall industrial o una DMZ OT. El acceso remoto de proveedores debe canalizarse a través de una solución de acceso remoto seguro (Secure Remote Access) con registro de sesión completo.

- **Lista blanca de aplicaciones (Application Whitelisting):** Solo las aplicaciones explícitamente autorizadas pueden ejecutarse en la HMI. Esta medida es más apropiada para el entorno OT que el antivirus convencional, porque el conjunto de aplicaciones legítimas es pequeño y estable. Impide la ejecución de malware incluso en sistemas sin parches.
- **Monitoreo del comportamiento de la HMI:** Detectar anomalías en el comportamiento del operador: acciones fuera del horario habitual, secuencias de comandos inusuales, acceso a páginas del sinóptico no normalmente visitadas. Un IDS OT puede correlacionar eventos de la HMI con el comportamiento del proceso para detectar inconsistencias.
- **Gestión de alarmas racionalizada (ISA-18.2):** Auditoría periódica del sistema de alarmas para eliminar alarmas redundantes, chattering y de bajo valor. Un sistema con pocas alarmas bien priorizadas es más resiliente al alarm flooding que uno con miles de alarmas permanentemente activas.

## 9. Cierre de la Unidad 2: El Sistema Completo.

Con este documento cerramos la Unidad 2 habiendo construido, capa a capa, el sistema de control industrial completo:

- **Doc N° 5 — El PLC:** El cerebro del sistema. Arquitectura, memorias, I/O y el ciclo de scan como mecanismo determinista y como superficie de ataque.
- **Doc N° 6 — Ladder y FBD:** La lógica que el cerebro ejecuta. La capacidad de leer, interpretar y auditar un programa de control como competencia de Ciberdefensa.
- **Doc N° 7 — La RTU:** La extensión del cerebro al territorio. Comunicaciones de largo alcance, el protocolo DNP3 sin autenticación y la superficie de ataque distribuida geográficamente.
- **Doc N° 8 — La HMI:** La interfaz entre el sistema técnico y el operador humano. El punto donde la manipulación de la información y la sobrecarga cognitiva se convierten en herramientas de ataque.

La Unidad 3 subirá un nivel de abstracción más: de los componentes individuales a los sistemas de supervisión completos (SCADA, DCS) y a los sectores de infraestructura crítica donde estos sistemas operan. Los protocolos industriales (Modbus, DNP3) que aparecieron como referencias en esta unidad serán analizados en detalle, y la arquitectura completa de la jerarquía de control — desde el sensor hasta la sala de mandos nacional — quedará expuesta en su totalidad.

## 10. Actividades de Verificación y Análisis.

1. Un ingeniero de OT propone conectar la HMI de la sala de control de una planta petroquímica directamente a la red corporativa para facilitar la generación automática de reportes de producción. ¿Qué riesgo de seguridad específico introduce esta decisión? ¿Qué contramedida de arquitectura de red recomendaría para obtener el beneficio operativo sin el riesgo?
2. Clasifique el alarm flooding según la tríada AIC. ¿A cuál de los tres principios ataca primariamente? ¿Podría afectar también a los otros dos? Justifique con un ejemplo concreto de cómo el alarm flooding puede derivar en una violación de la Integridad del proceso.
3. Compare el vector de ataque mediante USB (caso Stuxnet) con el vector de acceso remoto sin protección (caso Oldsmar) en términos de: requisitos de acceso físico del adversario, detectabilidad por herramientas de monitoreo de red, y dificultad de implementación de contramedidas. ¿Cuál representa un mayor riesgo en el contexto actual de convergencia IT/OT? Justifique.

4. Análisis de Caso Integrador: Como analista de Ciberdefensa, usted recibe el siguiente reporte de incidente en una planta de tratamiento de agua: (a) A las 02:15, el sistema de alarmas de la HMI principal comenzó a generar 45 alarmas por minuto durante 8 minutos. (b) A las 02:23, el operador de turno, desbordado por las alarmas, decidió silenciar el panel de alarmas temporalmente. (c) A las 02:31, un sensor físico independiente (no conectado a la red) detectó niveles de cloro anómalos en el efluente. (d) Al revisar el sinóptico de la HMI, el operador verificó que el sistema mostraba niveles de cloro normales. (e) Al revisar el servidor historian, se encontró que los datos de los últimos 20 minutos habían sido sobreescritos con valores normales. Identifique las fases del ataque, el tipo de técnicas utilizadas en cada fase, y los principios de la tríada AIC vulnerados en cada momento. ¿Qué contramedidas habrían interrumpido la cadena del ataque?

## 11. Glosario Mínimo.

**Alarm Flooding (Inundación de Alarmas):** Técnica de ataque que genera un volumen de alarmas en la HMI superior a la capacidad cognitiva del operador para procesarlas, con el objetivo de paralizar su capacidad de respuesta mientras se ejecuta el ataque principal sobre el proceso físico.

**Application Whitelisting (Lista Blanca de Aplicaciones):** Medida de seguridad que permite la ejecución únicamente de aplicaciones explícitamente autorizadas en un sistema. Alternativa al antivirus convencional especialmente adecuada para entornos OT con software estable y bien definido.

**Conciencia Situacional (Situational Awareness):** Capacidad del operador de percibir el estado actual del proceso, comprender su significado y proyectar su evolución futura. La HMI es el principal instrumento de soporte a la conciencia situacional. Su compromiso degrada directamente esta capacidad.

**Historian (Servidor Historian):** Componente del sistema SCADA que almacena el registro histórico temporal de todas las variables del proceso con marca de tiempo. Es la fuente de datos para el display de tendencias y la evidencia primaria en el análisis forense de incidentes OT.

**KillDisk:** Malware destructivo utilizado en el ataque a la red eléctrica ucraniana de 2015 que sobreescribe el Master Boot Record (MBR) del disco del sistema, dejando el equipo imposible de arrancar y destruyendo la evidencia digital del ataque.

**Pivoting:** Técnica de ataque que utiliza un nodo ya comprometido como trampolín para acceder a otros segmentos de red inaccesibles directamente. En entornos IT/OT convergidos, la HMI es el nodo de pivoting típico para pasar de la red corporativa a la red industrial.

**Sinóptico:** Representación gráfica del proceso físico supervisado en la HMI, que muestra la topología del sistema (tuberías, válvulas, equipos) y superpone sobre ella los valores en tiempo real de las variables de proceso. Es el elemento central de toda HMI industrial.

**Spear Phishing:** Variante del phishing dirigida a individuos específicos (en lugar de envíos masivos), utilizando información personalizada sobre la víctima para aumentar la credibilidad del engaño. Es el vector de entrada inicial documentado en el ataque Industroyer a Ucrania 2015.

## 12. Referencias Bibliográficas.

ANSI/ISA-18.2-2016. Management of Alarm Systems for the Process Industries. Research Triangle Park, NC: ISA.

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security: Securing Critical Infrastructure Networks for Smart Grid, SCADA, and Other Industrial Control Systems (2da ed.). Waltham, MA: Syngress. (Capítulo 2, sección: The HMI; Capítulo 10: Hacking the HMI).

Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., & Lightman, S. (2023). Guide to Operational Technology (OT) Security (NIST Special Publication 800-82 Revision 3). Gaithersburg, MD: NIST. (Sección 3.2: Recommended Security Controls for ICS; Sección 4.2: HMI Vulnerabilities).

Lee, R., Assante, M., & Conway, T. (2016). Analysis of the Cyber Attack on the Ukrainian Power Grid. Washington, DC: SANS ICS / E-ISAC.

Cátedra Tecnología Operativa (2026). Ficha de Cátedra N°3: Vectores de Ataque en Infraestructura Física. FADENA.